

Kolibri CRM — Seguridad y Resiliencia

Entregable 4 · Ecosistema de Automatización IA Autónomo · Entrega Final — Coderhouse
AI Automation

Este documento describe cómo el ecosistema protege credenciales y datos, cómo se comporta ante fallas reales (probadas en el Entregable de testing), y qué controles humanos y técnicos evitan que un error o una alucinación de la IA lleguen a producción sin supervisión.

1. Gestión de credenciales y accesos

Ninguna credencial vive en el código del flujo ni en las bases de Notion: todas están guardadas en el gestor de credenciales cifrado de n8n (Credentials), referenciadas por nombre desde cada nodo.

Credencial	Tipo	Alcance (scope) de uso
Notion account	Notion API (OAuth)	Leer/escribir en Centro de Comando, Base RAG y Log de Errores
Anthropic account	API Key (Anthropic)	Llamar a Claude API (nodo Message a Model)
Gmail account	Gmail OAuth2	Enviar el correo de aprobación HITL y esperar la respuesta

Principio de menor privilegio: cada credencial solo tiene el permiso mínimo necesario para su nodo (ej. Gmail solo envía y lee respuestas de aprobación, no tiene acceso de lectura al resto de la bandeja).

Rotación: los tokens OAuth de Notion y Gmail se reconectan manualmente desde n8n (Credentials → Reconnect) cuando expiran — este caso ocurrió y fue documentado durante las pruebas (ver sección 3). El n8n instance corre localmente, no está expuesto públicamente en internet, lo que reduce la superficie de ataque frente a una instancia cloud abierta.

2. Manejo de errores y reintentos automáticos

Los tres nodos críticos del flujo — donde una falla de red o de servicio externo es más probable — tienen configurado el mismo patrón de resiliencia a nivel de nodo:

Nodo crítico	Retry on Fail	Comportamiento ante fallo final
Message a Model (Claude API)	3 intentos, 1000ms entre intentos	Continuar con salida de error
Create/Update página (Notion)	3 intentos, 1000ms entre intentos	Continuar con salida de error
Send message and wait for response (Gmail)	3 intentos, 1000ms entre intentos	Continuar con salida de error

Si los 3 reintentos fallan, el nodo no interrumpe todo el flujo: enruta la ejecución por su salida de "Error" hacia un nodo dedicado que escribe una fila en **Log de Errores** (Notion) con el mensaje de error, el nodo responsable, la fecha y la acción tomada — y la ejecución termina de forma controlada en vez de quedar colgada o silenciosamente perdida.

3. Registro, trazabilidad y versionado

- **Log de Errores (Notion):** historial permanente y consultable de toda falla real del sistema, con causa raíz y acción tomada.
- **Executions history (n8n):** cada ejecución del flujo (exitosa, en espera o con error) queda registrada con timestamp, duración e input/output de cada nodo — usado durante el testing para diagnosticar la falla real de credencial de Gmail (error de septiembre 2026, credencial OAuth expirada) antes de corregirla.
- **Autosave / historial de versiones (n8n):** cada cambio guardado del workflow queda versionado, permitiendo revertir una modificación que rompa el flujo.

4. Human-in-the-loop como control de seguridad

El control de seguridad más importante del sistema no es técnico sino de diseño: **ninguna pieza de contenido generada por IA se publica sin aprobación humana explícita**. El nodo Gmail "Send and Wait for Response" pausa la ejecución real del flujo (no es un timeout ni una simulación) hasta que Sam hace click en Aprobar o Rechazar desde el correo recibido. Esto acota el riesgo de una alucinación, un tono fuera de marca, o información incorrecta generada por el modelo — el peor caso posible es una pieza rechazada, nunca una publicación indebida.

5. Continuidad y recuperación ante fallos

Escenario de falla	Comportamiento del sistema	Acción de recuperación
Notion no responde / rate limit	El nodo agota sus 3 reintentos y registra el error en el Log; la fila en Centro de Comando queda en su último estado consistente (no se pierde la Idea_Semilla).	Reintentar manualmente la ejecución desde n8n una vez restablecido el servicio.
Claude API no responde / error de cuota	Igual que arriba: se registra el error, no se genera contenido a medias.	Revisar cuota/estado de Anthropic y re-ejecutar el nodo.
Credencial de Gmail expirada	El envío del correo de aprobación falla; se registra en el Log de Errores con Nodo_Fallido = Gmail.	Reconectar la credencial (Credentials → Switch account) — validado end-to-end durante el testing.
n8n/host local apagado	El flujo completo no procesa nuevas ideas hasta que la instancia vuelva a estar activa; no hay pérdida de datos porque Notion es la fuente de verdad.	Reiniciar la instancia de n8n; el Notion Trigger retoma el polling normalmente.

6. Riesgos conocidos y limitaciones

- **Punto único de aprobación:** hoy solo Sam recibe y responde el correo de aprobación — si está fuera de línea por un período largo, el contenido queda pendiente indefinidamente. Mejora futura: agregar un segundo aprobador o un timeout con escalamiento.
- **Instancia local de n8n:** al no estar en la nube, el flujo solo corre mientras la computadora esté encendida y la instancia activa — no hay alta disponibilidad. Aceptable para el volumen actual, a revisar si el proyecto escala a agencia.
- **Sin límite de tasa (rate limiting) propio:** el flujo confía en los límites de los proveedores (Notion, Anthropic, Gmail); un pico inesperado de ideas cargadas podría generar throttling. Mitigado en la práctica por el bajo volumen actual (ver Entregable 3).
- **Sin cifrado adicional de contenido:** el contenido generado y el conocimiento RAG viven en Notion tal cual — aceptable porque no se maneja información sensible de clientes ni datos personales de terceros en las bases actuales.

7. Checklist de seguridad operativa (mantenimiento periódico)

- Revisar el Log de Errores semanalmente (ver Entregable 2, sección 5.4).

- Verificar que las 3 credenciales (Notion, Anthropic, Gmail) estén activas antes de una carga masiva de ideas.
- Confirmar que el nodo Gmail sigue configurado con Retry on Fail + Continue Using Error Output tras cualquier edición del flujo.
- No compartir las credenciales de n8n fuera del equipo autorizado (Sam / Blue Sheep Digital).
- Ante un error recurrente en el mismo nodo, tratarlo como incidente y no solo reintentar manualmente sin investigar la causa raíz.